

SOCIAL ENGINEERING

Connecting the *dots*

Jirapat K.
Backend Engineer

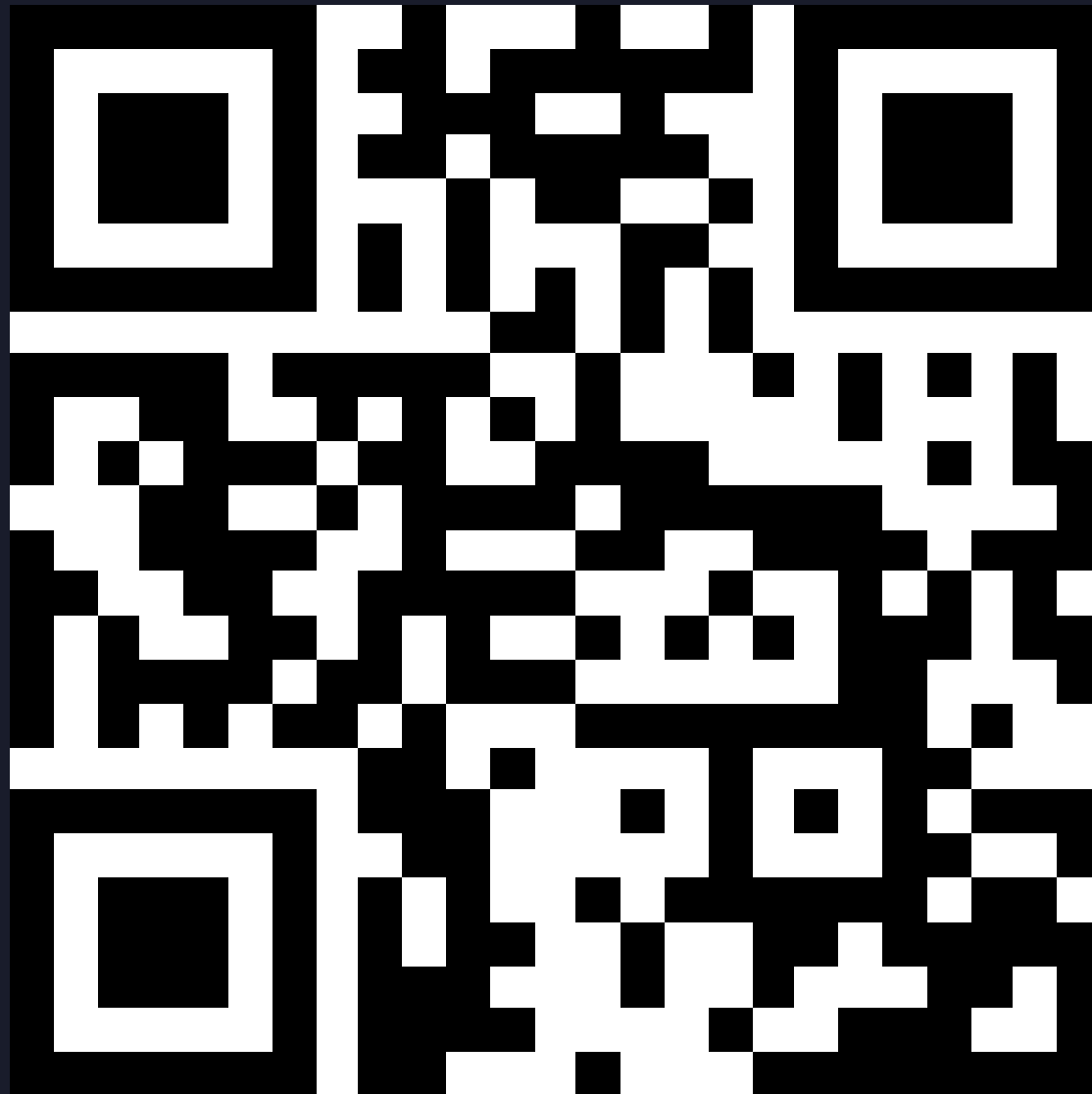


Topics

1. Overview
2. Domains in Social Engineering
3. Application Examples

PRE-TEST

Let's check your knowledge first!

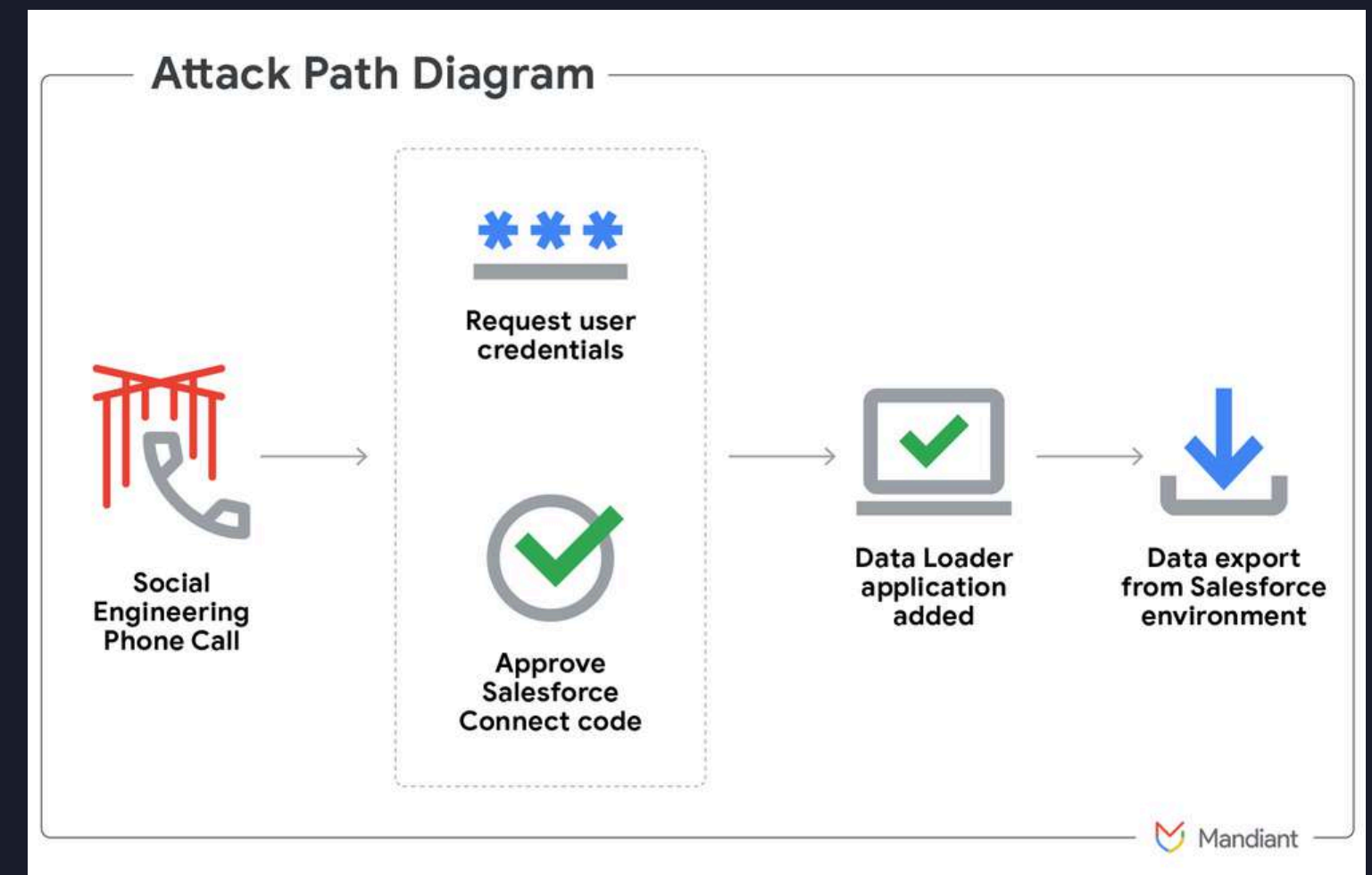


Have you ever heard
Social Engineering?

The Cost of a Call: From Voice Phishing to Data Extortion

June 5, 2025

Over the past several months, UNC6040 has demonstrated repeated success in breaching networks by having its operators impersonate IT support personnel in convincing telephone-based social engineering engagements. This approach has proven particularly effective in tricking employees, often within English-speaking branches of multinational corporations, into actions that grant the attackers access or lead to the sharing of sensitive credentials, ultimately facilitating the theft of organization's Salesforce data. In all observed cases, attackers relied on manipulating end users, not exploiting any vulnerability inherent to Salesforce.



<https://cloud.google.com/blog/topics/threat-intelligence/voice-phishing-data-extortion>

SOCIAL ENGINEERING DEFINITION

Short

A type of attack wherein the attacker exploit human vulnerability through social interaction to breach cyberspace security

Long

A type of attack in which the attacker exploit human vulnerabilities (by means such as influence, per suasion, deception, manipulation and inducing) to breach the security goals (such as confidentiality, integrity, avail ability, controllability and auditability) of cyberspace elements (such as infrastructure, data, resource, user and operation)

REFERENCE

Cybersecurity

About Articles Submission Guidelines Submit manuscript

Research | Open access | Published: 02 August 2021

Social engineering in cybersecurity: a domain ontology and knowledge graph application examples

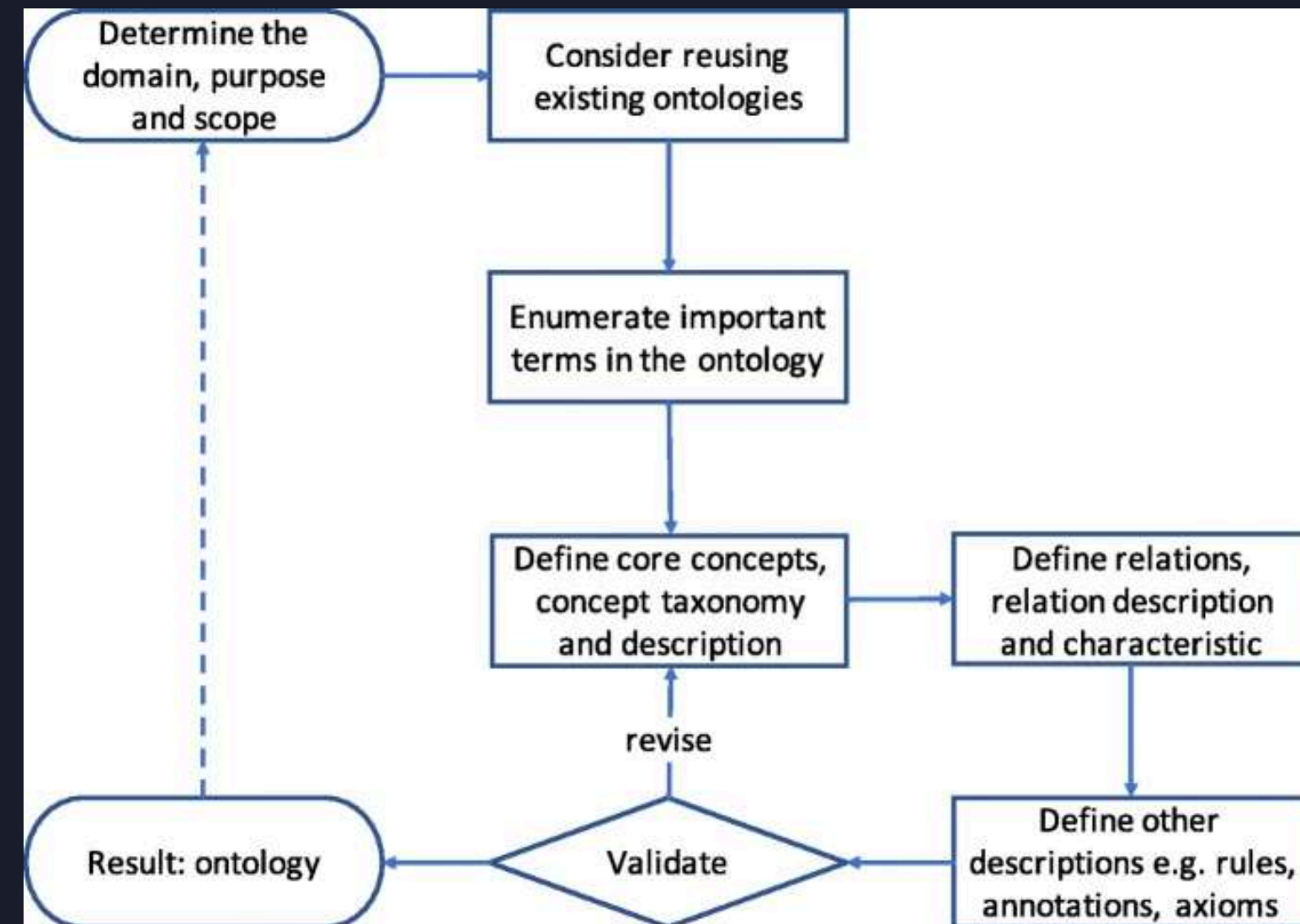
Zuoguang Wang, Hongsong Zhu, Peipei Liu & Limin Sun

Cybersecurity 4, Article number: 31 (2021) | Cite this article

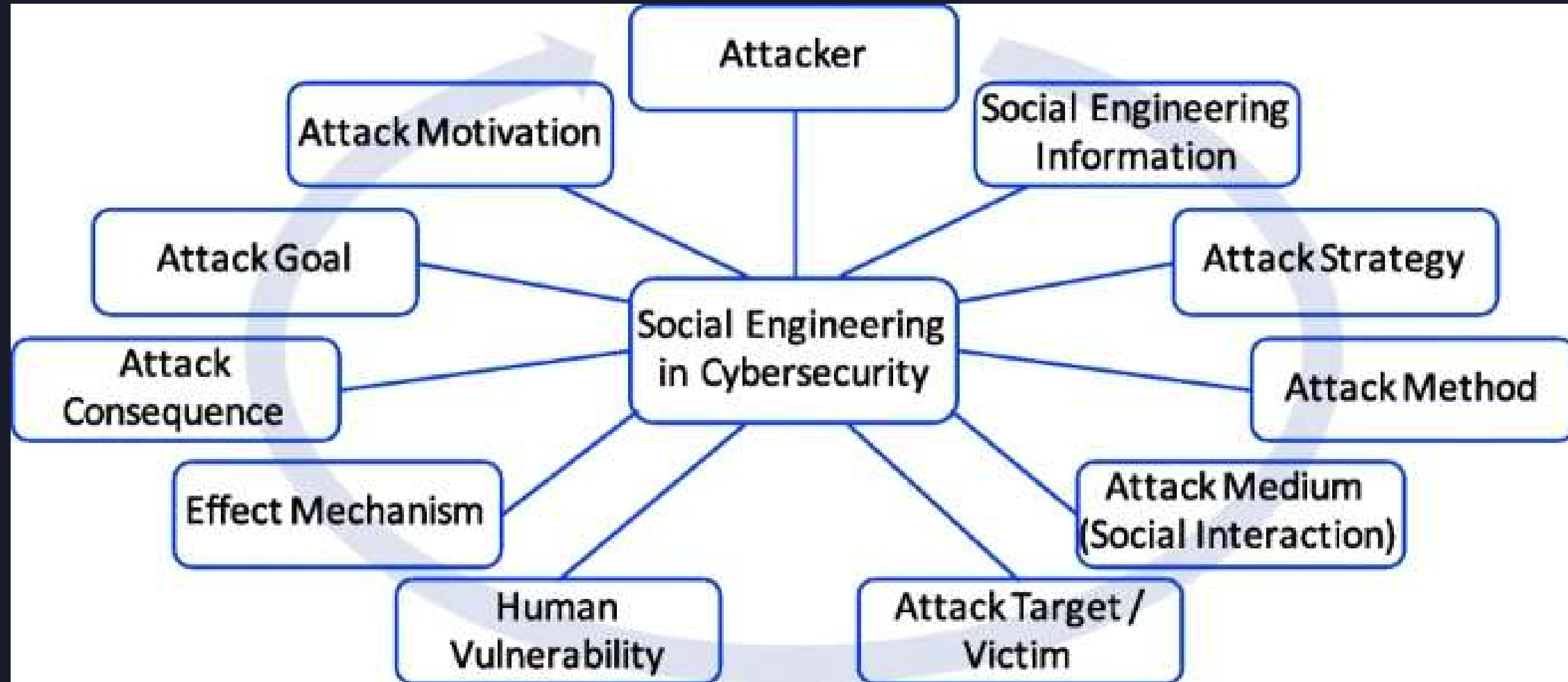
24k Accesses | 45 Citations | 2 Altmetric | Metrics

Abstract

Social engineering has posed a serious threat to cyberspace security. To protect against social engineering attacks, a fundamental work is to know what constitutes social engineering. This paper first develops a domain ontology of social engineering in cybersecurity and conducts ontology evaluation by its knowledge graph application. The domain ontology defines 11 concepts of core entities that significantly constitute or affect social engineering domain, together with 22 kinds of relations describing how these entities related to each other. It provides a formal and explicit knowledge schema to understand, analyze, reuse and share domain knowledge of social engineering. Furthermore, this paper builds a knowledge graph based on 15 social engineering attack incidents and scenarios. 7 knowledge graph application examples (in 6 analysis patterns) demonstrate that the ontology together with knowledge graph is useful to 1) understand and analyze social engineering attack scenario and incident, 2) find the top ranked social engineering threat elements (e.g. the most exploited human vulnerabilities and most used attack mediums), 3) find potential social engineering threats to



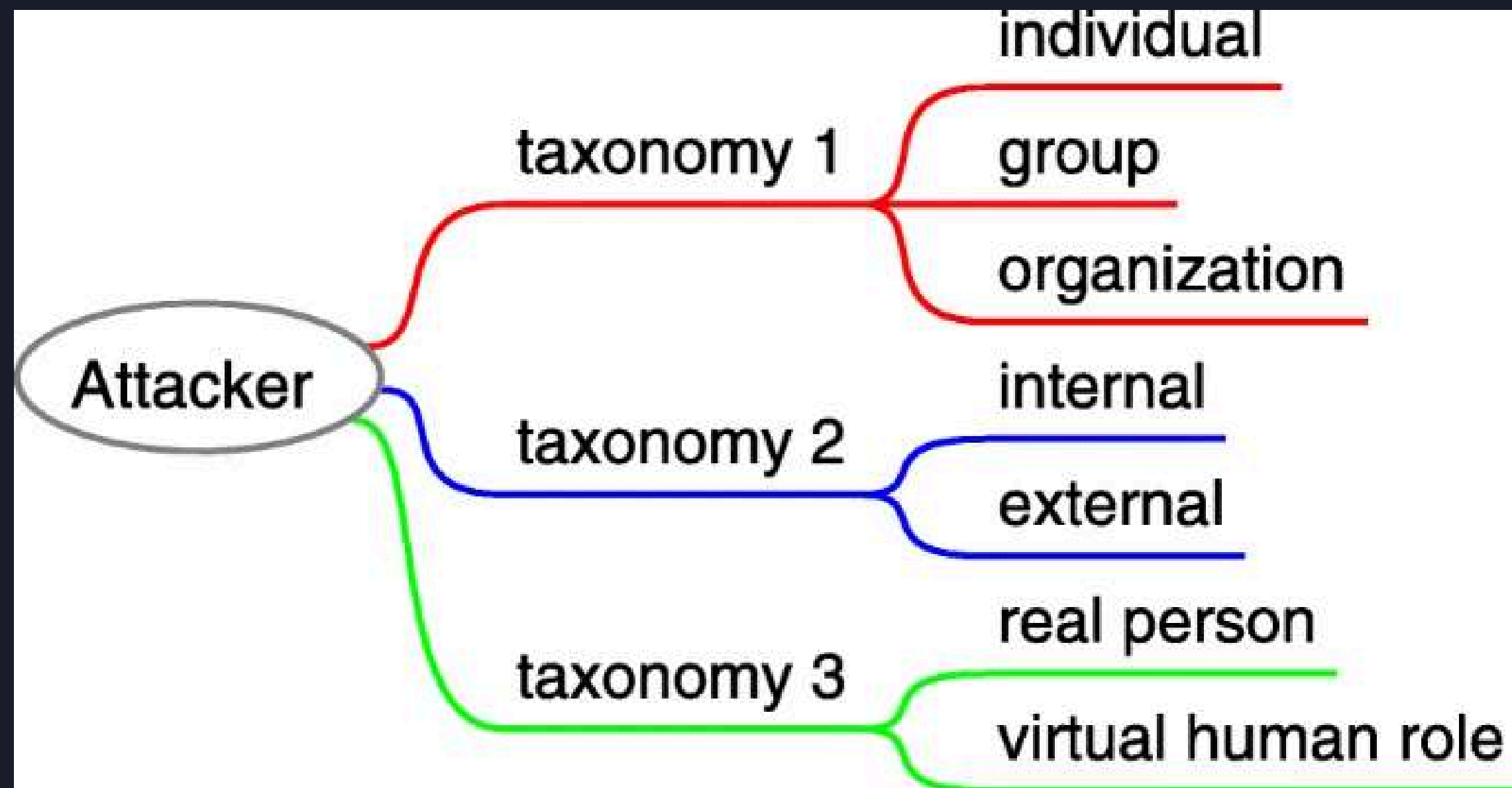
CORE DOMAINS



11 DOMAINS IN SOCIAL ENGINEERING

ATTACKER

the attacker (a.k.a. social engineer) is the party to conduct a social engineering attack.



ATTACK MOTIVATION

the factors that motivate the attacker to conduct a social engineering attack.



Financial Gain



Personal Interest



Terrorism

ATTACK GOAL AND OBJECT

something that the attacker wants to achieve.

Intuitive

- Network intrusion
- Gain unauthorized access to information
- Infrastructure sabotage
- Obtain physical access to restricted areas
- etc.

Breach Security Goal

- Confidentiality
- Integrity
- Availability
- Controllability
- Auditability

Breach Cyberspace Element

- Carrier (the infrastructure, hardware and software facilities of cyberspace)
- Resources (the objects, data content that flows through the cyberspace)
- Subjects (the main body roles and users, including human users, organizations, etc.)
- Operations (all kinds of activities of processing Resources, including creation, change, use, etc.)

SOCIAL ENGINEERING INFORMATION

any information that helps the attacker to conduct a social engineering attack.



Social Space

- Individual Identification
- Behavior
- Job Information



Cyber Space

- IP address
- Account Information
- App version



Physical Space

- Location
- Building Structure

THEY SEE YOUR PHOTOS

THEYSEE YOURPHOTOS

Your photos reveal a lot of private information.

In this experiment, we use the Google Vision API to see how much can be inferred about you from a *single* photo.

See what they see.

By
ente

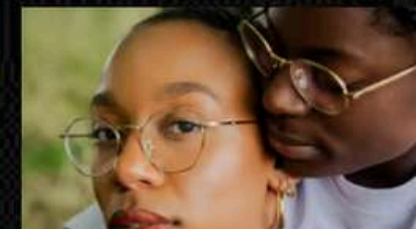
[Terms](#)

[Privacy](#)



Pick a photo

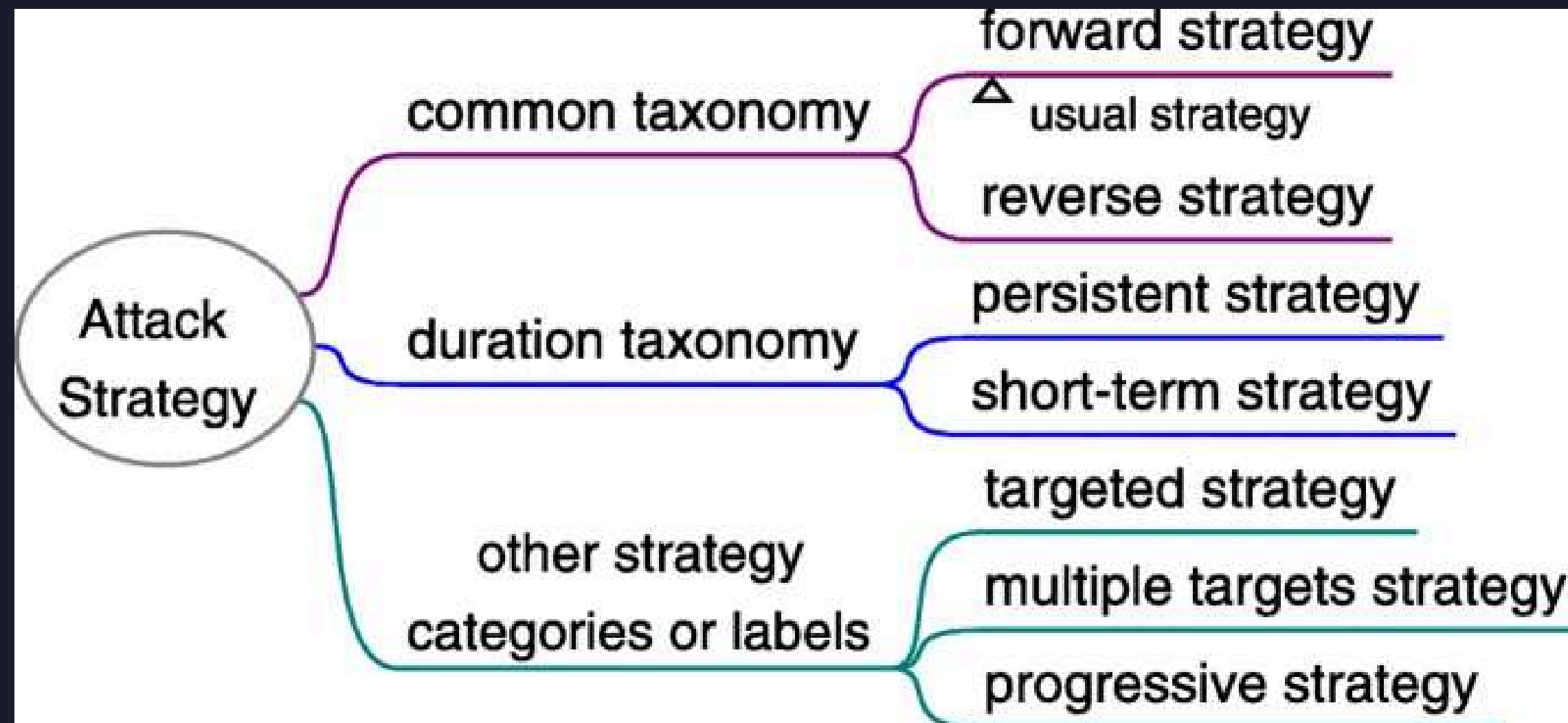
or



<https://theyseeyourphotos.com/>

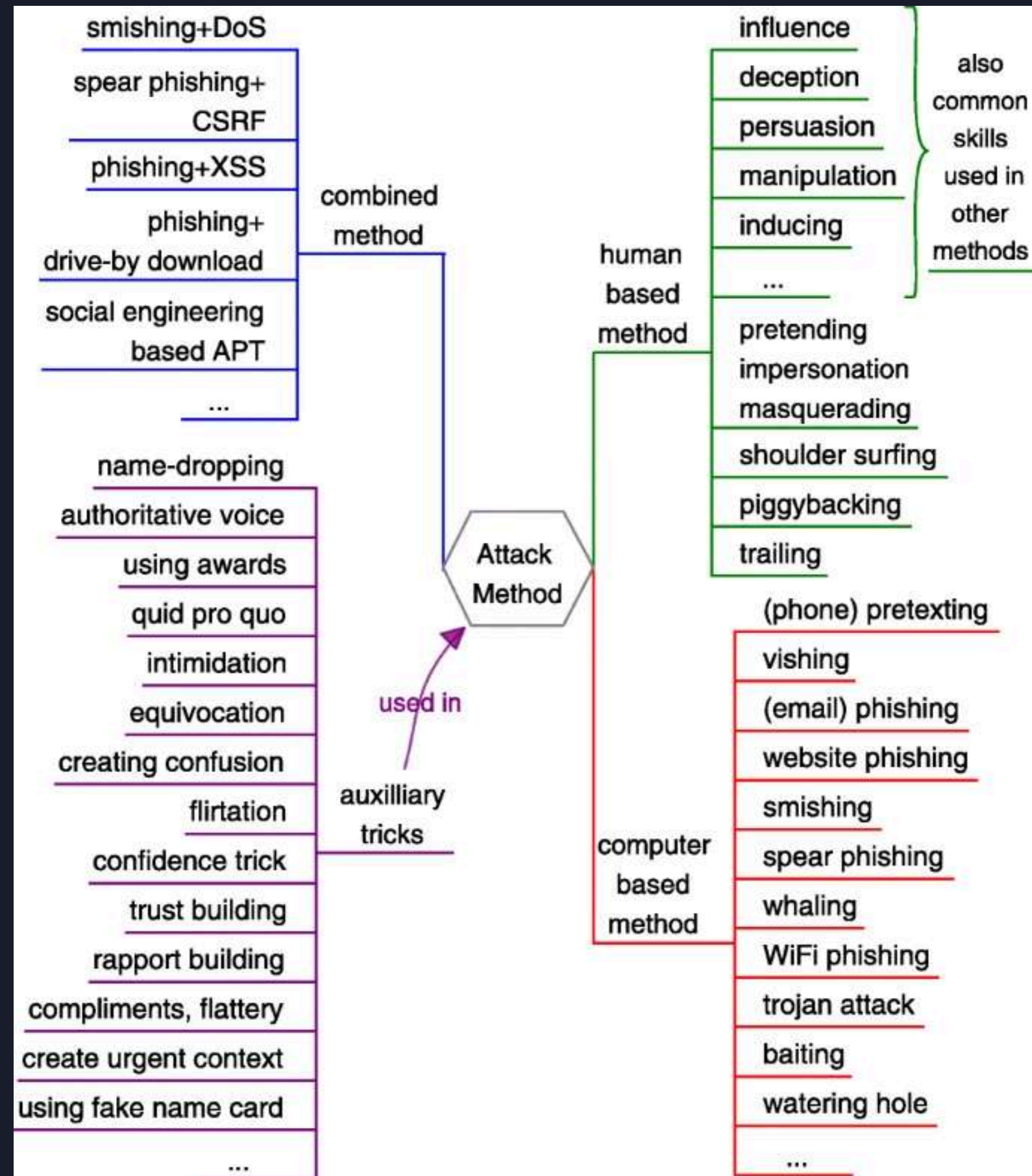
ATTACK STRATEGY

plan, pattern, or guidance of actions formulated by the attacker for certain attack goal.



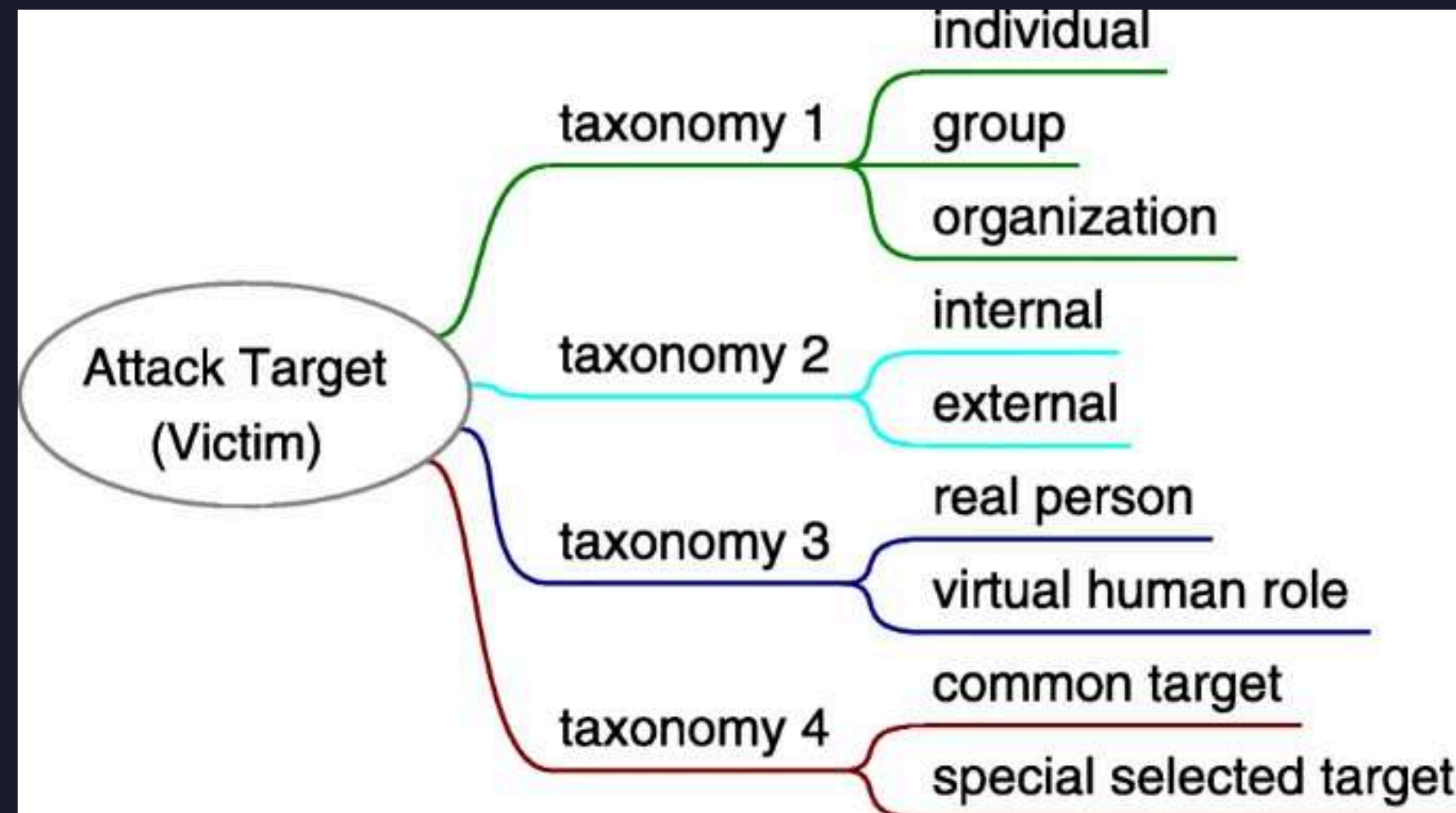
ATTACK METHOD

the way of carrying an attack out; the attacker crafts and performs it to achieve specific attack goal.



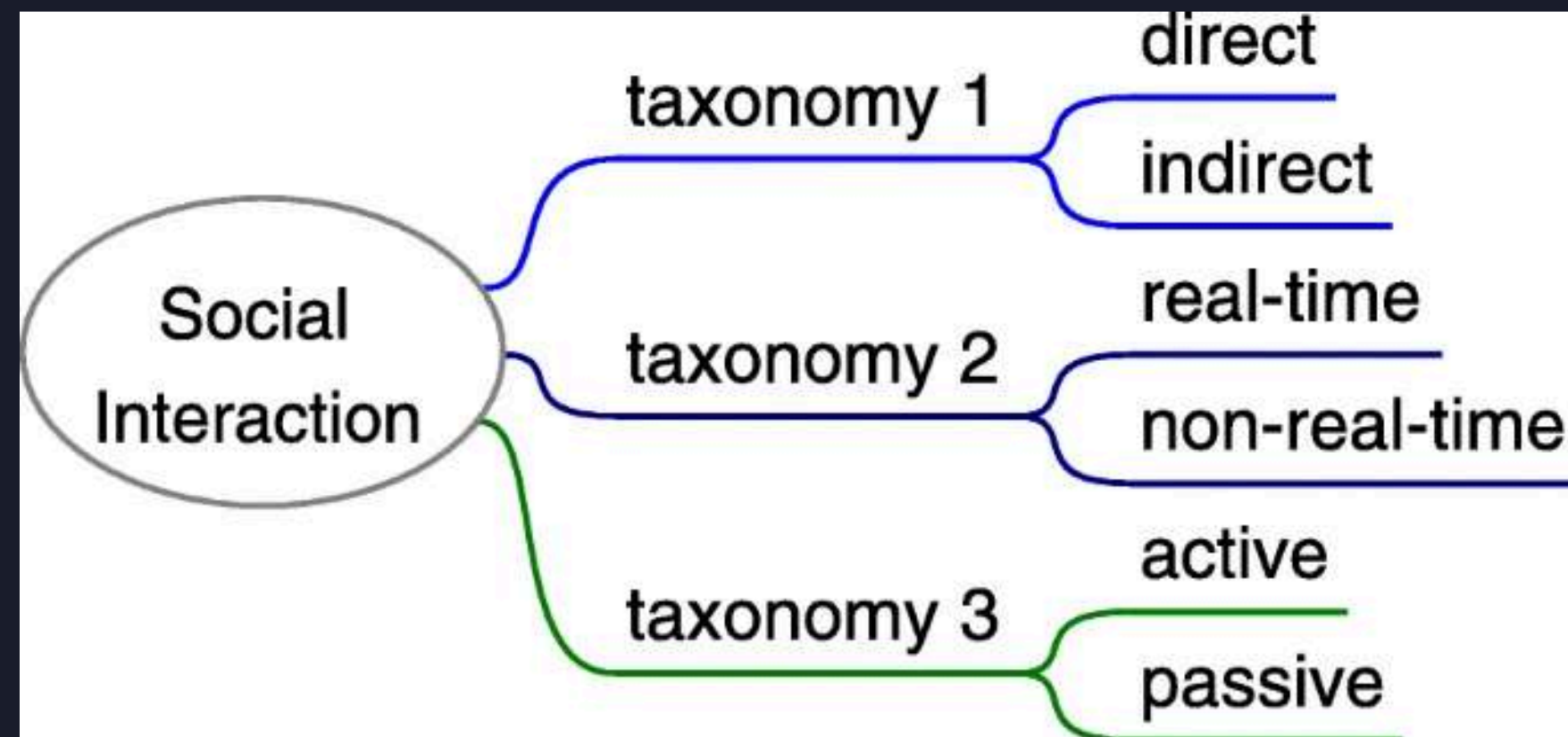
ATTACK TARGET

attack target is the party to suffer a social engineering attack and bring about an attack consequence.



SOCIAL INTERACTION & ATTACK MEDIUM

the substance or channel through which attack methods are carried out.



Examples

- Attach files
- Manual
- Video
- RFID tag
- QR code
- Bluetooth
- Portable storage
- etc.

HUMAN VULNERABILITY

the human factor exploited by the attacker to conduct a social engineering attack.

Cognition and Knowledge

1. ignorance
2. inexperience
3. thinking set and stereotyping
4. bias
5. conformity
6. intuitive judgement
7. low level of need for cognition
8. heuristics and mental shortcuts

Behavior and Habit

1. laziness
2. carelessness and thoughtlessness
3. fixed-action patterns
4. behavioral habits

Emotions and Feelings

1. fear
2. curiosity
3. anger
4. excitement
5. tension
6. happiness
7. sadness
8. disgust
9. surprise
10. guilt
11. impulsion
12. fluke mind

HUMAN VULNERABILITY (CONT.)

the human factor exploited by the attacker to conduct a social engineering attack.

Human Nature

- 1.self-love
- 2.sympathy
- 3.helpfulness
- 4.greed
- 5.gluttony
- 6.lust

Personality Traits

- 1.conscientiousness
- 2.extraversion
- 3.agreeableness
- 4.openness
- 5.neuroticism

Individual characters

- 1.credulity
2. friendliness
3. kindness and charity
- 4.courtesy
- 5.humility
- 6.diffidence
- 7.apathy
- 8.hubris
- 9.envy

EFFECT MECHANISM

the structural relation that what, why or how specific attack effect corresponds to specific human vulnerability.

Persuasion

distraction in persuasion and manipulation

Trust and Deception

factor affecting trust, interpersonal deception theory (IDT)

Influence

informational influence (social proof)

Language, Thought and Decision

language invoke confusion

Cognition, Attitude and Behavior

impression management theory

Emotion and Decision-making

facial action coding, neurophysiological mechanism

ATTACK CONSEQUENCE

something that follows as a result or effect of a social engineering attack. The attacker feed it back to the attack goal to decide whether a further attack is required.

Intuitive

- Network intrusion
- Gain unauthorized access to information
- Infrastructure sabotage
- Obtain physical access to restricted areas
- etc.

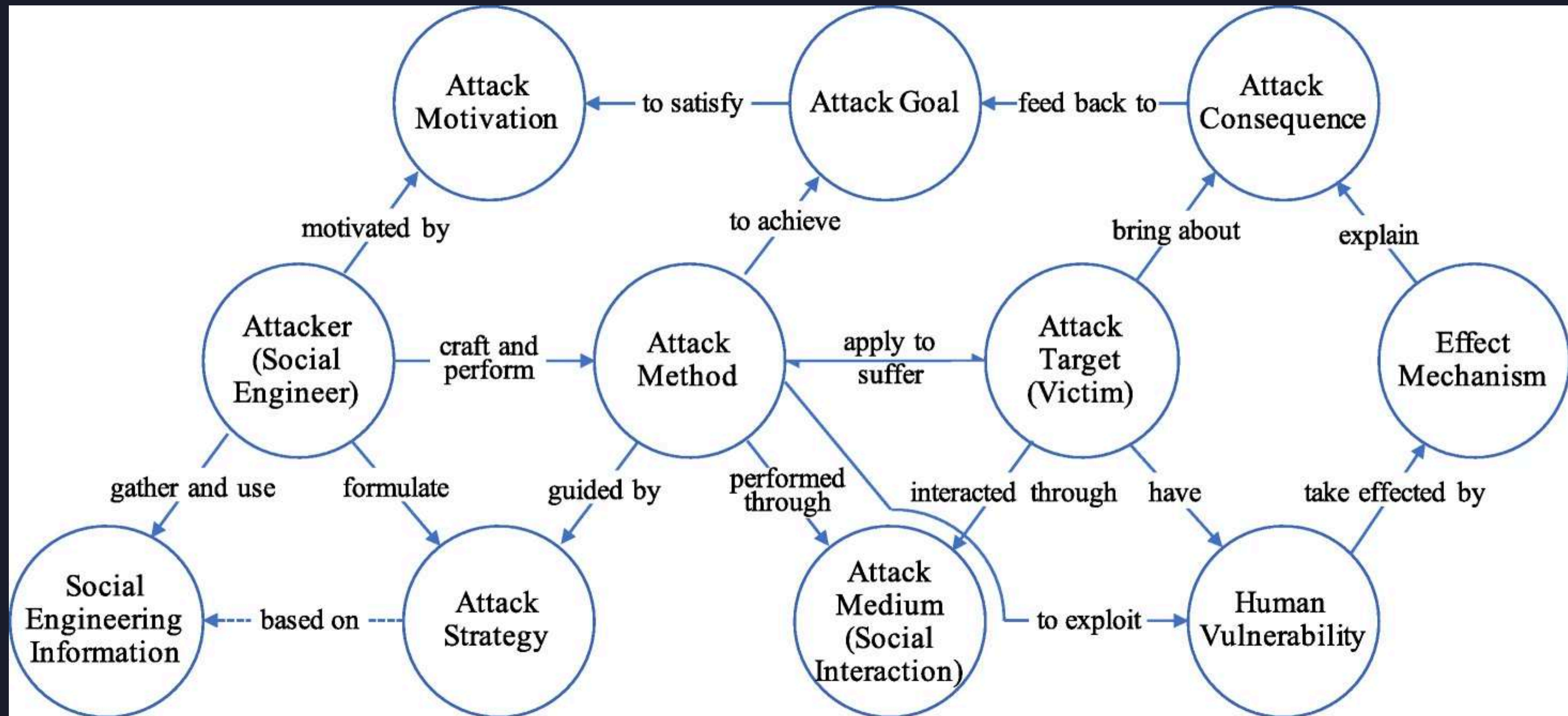
Breach Security Goal

- Confidentiality
- Integrity
- Availability
- Controllability
- Auditability

Breach Cyberspace Element

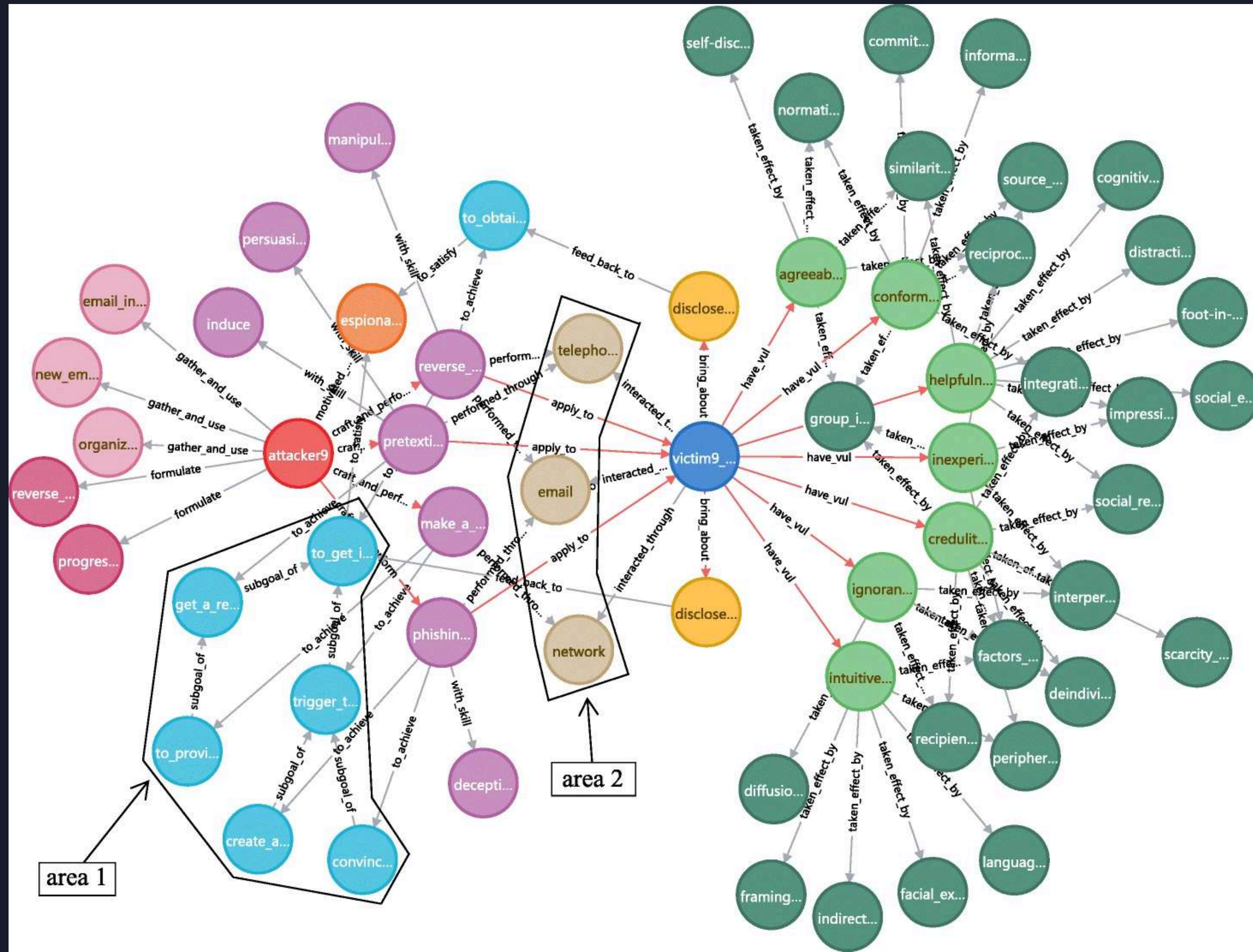
- Carrier (the infrastructure, hardware and software facilities of cyberspace)
- Resources (the objects, data content that flows through the cyberspace)
- Subjects (the main body roles and users, including human users, organizations, etc.)
- Operations (all kinds of activities of processing Resources, including creation, change, use, etc.)

DOMAIN ONTOLOGY



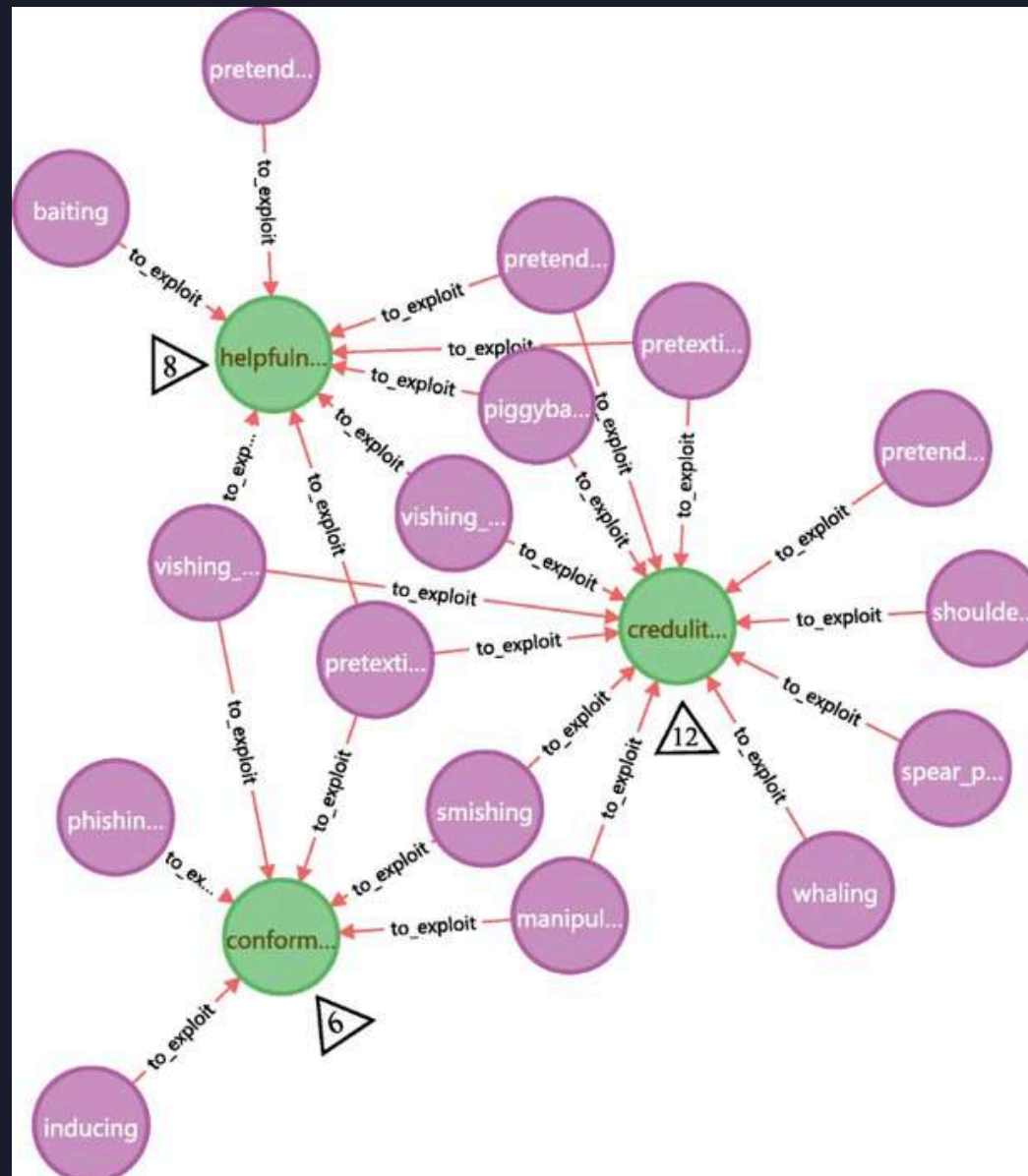
APPLICATION EXAMPLES

Analyze single social engineering attack scenario or incident



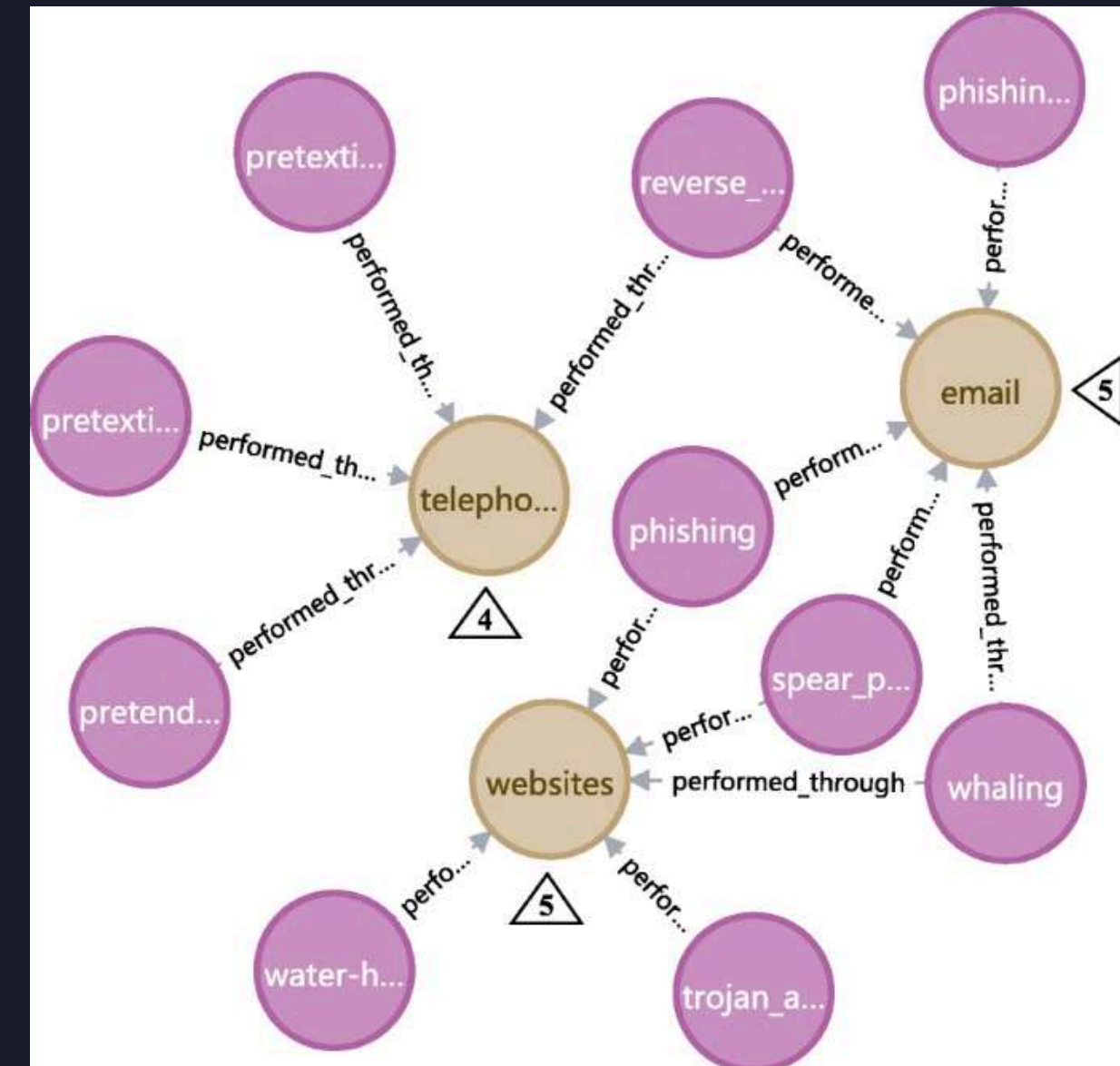
Analyze the Most exploited human vulnerabilities

1. Credulity
2. Helpfulness
3. Conformity



Analyze the Most used attack mediums and interaction forms

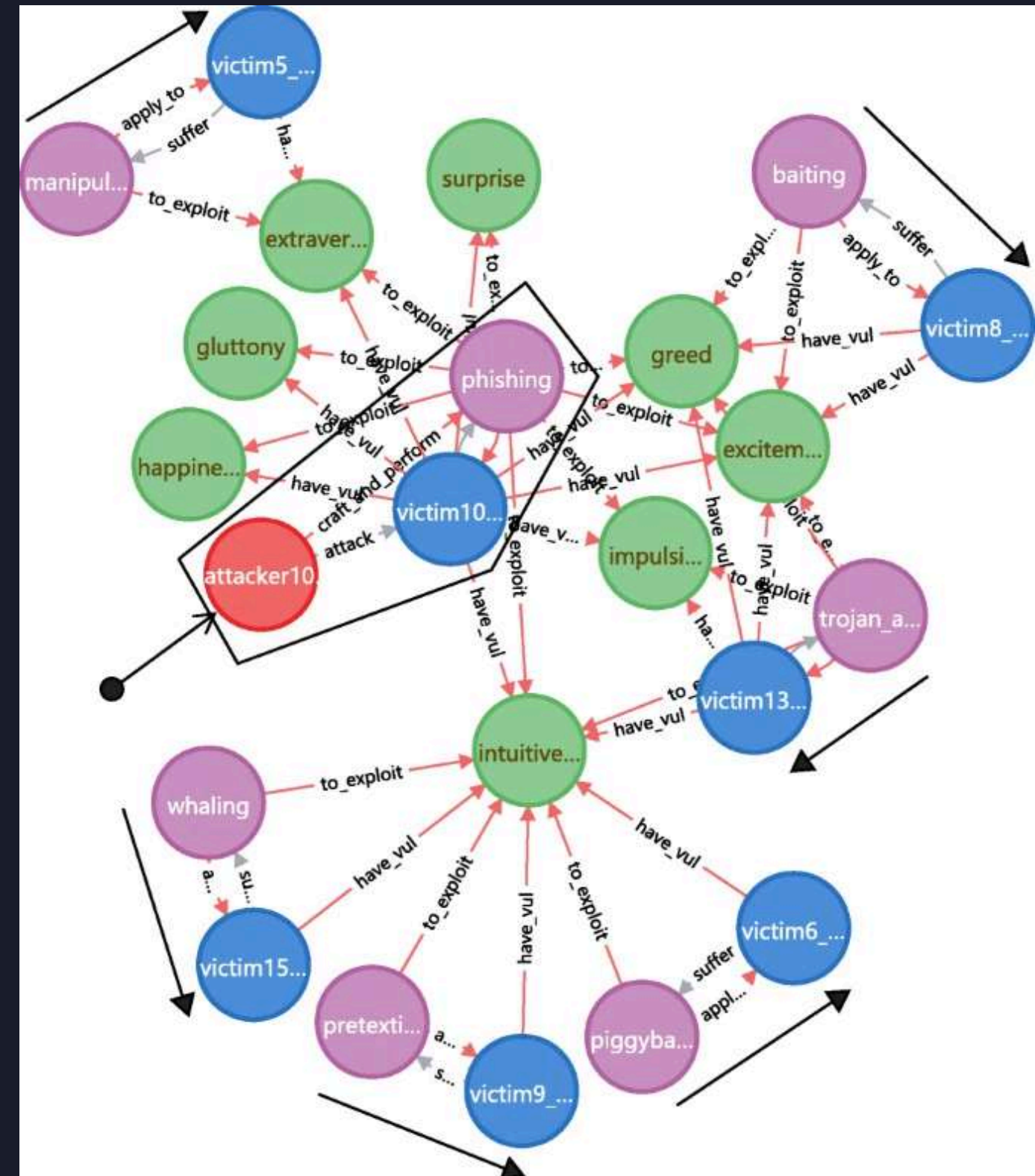
1. Email
2. Website
3. Telephone



Find additional (potential) threats for victims

if $(v1) \rightarrow (hv)$ in S1 and
 $(a2) \rightarrow (am2) \rightarrow (hv) \leftarrow (v2)$ in S2
 then $(a2) \rightarrow (am2) \rightarrow (hv) \leftarrow (v1)$ is **feasible**

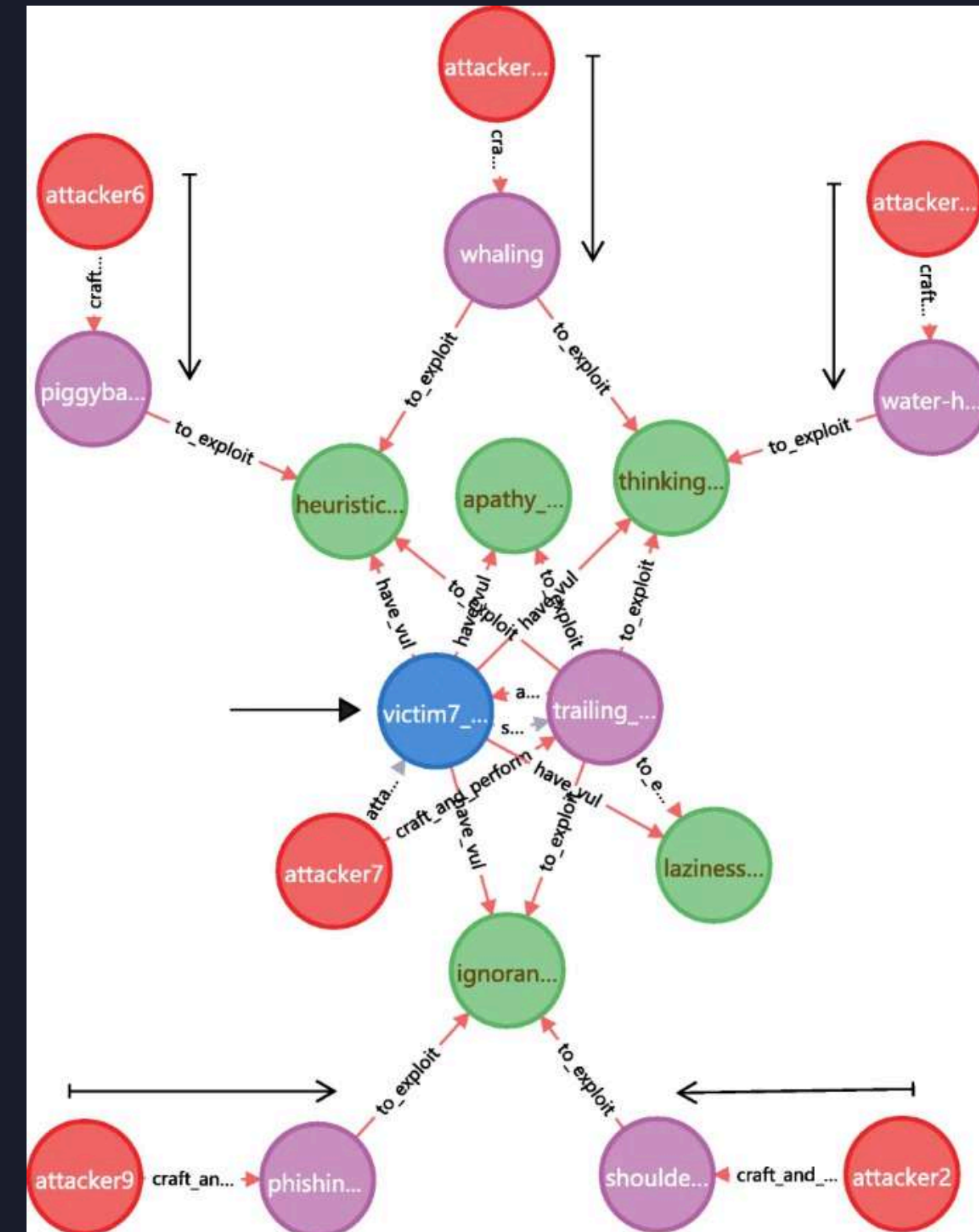
If two victims share the same vulnerability, and one of them is attacked by an attacker exploiting that weakness, it is possible that the attacker could also pose a threat to the other victim with the same vulnerability.



Find potential targets for attackers

if $(a1) \rightarrow (am1) \rightarrow (hv) \leftarrow (v1)$ in $S1$ and
 $(am2) \rightarrow (hv) \leftarrow (v2)$ in $S2$
then $(a1) \rightarrow (am1 \text{ or } am2) \rightarrow (hv) \leftarrow (v1)$ is **feasible**

If one victim is exploited through a certain human weakness, and another person has the same weakness, then the attacker could also target the second person — either in the same way or with a different method.



Remember, the best antivirus is still...

Awareness

Unfortunately, it doesn't *update automatically*.